SIMATS ENGINEERING ASSESSMENT TOOL III – Penetration testing Task

Course:	**Code:**	**CO:** CO3
Duration: 90 min	**Total Marks: 50**	**Reg No / Name :R.Dinesh-192421117**

COURSE OUTCOME COVERED

CO3: *Analyze network services using port scanning, ping sweeps, and enumeration techniques across different operating systems to identify vulnerabilities.(BL4) Duration: 90 min*

Instructions: Answer all questions. Each question carries 10 marks.

1. An organization has commissioned an external penetration test to determine how much information an unauthorized attacker could gather about its internet-facing infrastructure without directly attacking its systems. Using the **theHarvester** tool against the authorized domain **tesla.com**, conduct a comprehensive reconnaissance exercise to identify publicly available email addresses, subdomains, hostnames, IP

addresses, URLs, and other relevant infrastructure information. Organize and analyze the collected information to determine how it contributes to the external attack surface, including the risks associated with exposed employee information, unnecessary subdomains, hostnames, and externally hosted services. Finally, prepare a security assessment explaining the information discovered, the most valuable reconnaissance findings, how multiple pieces of information could be combined by an attacker, the associated risks, recommended controls to reduce information disclosure, and which findings should be validated during

subsequent penetration-testing phases. **Required Tool: theHarvester.** 2. During a penetration-testing engagement, assess the publicly accessible web application **testphp.vulnweb.com** using the **Nikto** tool to identify potentially exposed files and directories, insecure HTTP methods, server configuration weaknesses, information-disclosure issues, outdated components, dangerous files, and other potential security weaknesses. For every significant finding, collect appropriate evidence and determine whether it represents a confirmed vulnerability, a configuration weakness, or an issue requiring further manual validation. Prepare a final assessment including the commands used, significant findings, supporting evidence, potential security impact, likelihood of exploitation, recommended remediation measures, methods for validating remediation, and a prioritized list of the most important findings, with particular attention to exposed files, server-version information, directory listings, insecure HTTP methods, and outdated components. **Required Tool: Nikto.** 3. A company is conducting an external security assessment to determine whether its DNS infrastructure discloses more information than intended. Using the **Dig**utility against the

authorized target domain **zonetransfer.me**, perform a detailed DNS enumeration exercise by identifying and documenting the available A, AAAA, MX, NS, CNAME, TXT, SOA, and other relevant DNS records, determining the authoritative servers, and assessing whether an unauthorized DNS zone transfer can be requested. Analyze the results from an attacker's perspective and explain how DNS records can reveal mail infrastructure, server naming conventions, hostnames, service relationships, and other infrastructure

information. Your assessment should identify the DNS records and authoritative servers, determine whether a zone transfer was possible, explain the additional information exposed by a successful zone transfer and the risks of unrestricted AXFR access, discuss how DNS information can be combined with other reconnaissance techniques, recommend appropriate DNS security controls, and explain how remediation can be verified. **Required Tool: Dig.**

4. As part of an internal penetration-testing engagement, assess the authorized Windows/SMB target **192.168.1.100** using **Enum4linux** to determine what information could be obtained through SMB and NetBIOS enumeration before attempting exploitation. Perform comprehensive enumeration to identify available users, groups, shared resources, domain or workgroup information, operating system details, password-policy information, NetBIOS information, and other exposed SMB configuration details permitted by the target. Analyze the collected information from an attacker's perspective and determine whether it could facilitate credential attacks, privilege escalation, unauthorized access to shared resources, vulnerability identification, or lateral movement. Prepare a report containing the commands used, identified users and groups, discovered shared resources, relevant system and domain information, evidence of anonymous or null-session enumeration, security implications, relationships between accounts, groups and privileges, risks of unnecessarily accessible SMB shares, recommended controls, and a prioritized remediation plan covering SMB configuration, access control, authentication, patching, and network segmentation. **Required Tool: Enum4linux.**

5. During an external penetration-testing engagement, assess the authorized target **scanme.nmap.org** using **Netcat (nc)** to connect to accessible TCPservices and collect service responses and banner information. Analyze the responses to determine what technical information the target voluntarily discloses, including service type, protocol, software name, version information, HTTPresponse headers, operating-system clues, and other implementation details. For each significant observation, explain what information was disclosed, which service provided it, how it could assist an attacker with fingerprinting, whether version information could be correlated with known vulnerabilities, whether the finding represents a vulnerability or merely information disclosure, what additional validation is required, and what remediation measures could reduce unnecessary exposure. Finally, explain how the organization should monitor and periodically reassess externally exposed services and discuss the security implications of service-banner exposure and how accurate service fingerprinting can make subsequent attacks more targeted. **Required Tool: Netcat (nc).**

Code of Conduct:

I Dinesh R-192421117 certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: Dinesh R

1. Reconnaissance Using theHarvester – tesla.com

Aim

To collect publicly available information about the target domain using theHarvester and analyze the organization's external attack surface.

Commands

theHarvester -d tesla.com -b all

To save the output to a file, if supported by your installed version:

theHarvester -d tesla.com -b all -f tesla_report

Note: Available data sources depend on the installed version and configured API keys. If all is unsupported, check the available sources using:

theHarvester -h

Analysis

TheHarvester collects publicly available information from supported search engines and other data sources.

Information	**Description**	**Security Risk**
Email addresses	Publicly listed organizational email addresses	Targeted phishing
Subdomains	Names associated with the main domain	Discovery of additional entry points
Hostnames	Names of internet-facing systems	Infrastructure fingerprinting
IP addresses	Addresses associated with discovered hosts	Identification of exposed systems

URLs	Publicly indexed web addresses	Discovery of login pages and services
Technology information	Details available from supported sources	Targeted vulnerability research

These are categories of information the tool may discover, not verified findings for tesla.com.

Attack Surface Analysis

1. **Email addresses:** Attackers may use public email addresses to create targeted phishing messages.
2. **Subdomains:** Forgotten or misconfigured subdomains may expose unnecessary services.
3. **IP addresses:** Discovered addresses can help identify internet-facing systems requiring security review.
4. **Hostnames:** Naming patterns may reveal system roles and infrastructure relationships.
5. **URLs:** Public URLs may reveal login portals, APIs, or other application entry points.

Security Recommendations

- Remove unnecessary public DNS records and abandoned subdomains.
- Review exposed services and restrict access to administrative interfaces.
- Apply email security controls and employee phishing awareness training.
- Monitor newly created subdomains and internet-facing assets.
- Review public information for accidental disclosure of sensitive details.

Result

TheHarvester helps identify publicly available organizational information and supports external attack-surface assessment.

---

2. Web Server Assessment Using Nikto – testphp.vulnweb.com

Aim

To identify potential web server misconfigurations, exposed files, outdated components, and other security weaknesses using Nikto.

Commands

nikto -h http://testphp.vulnweb.com

To save the scan results:

nikto -h http://testphp.vulnweb.com -output nikto_report.txt

Analysis

Nikto checks web servers for common security issues.

Finding	Security Risk	Recommended Solution
Outdated software	Known vulnerabilities may be exploitable	Update server software
Exposed files	Sensitive information may be disclosed	Remove or restrict access to sensitive files
Directory listing	Reveals files and directory structure	Disable directory listing
Missing security headers	May increase exposure to certain attacks	Configure appropriate security headers
Server version disclosure	Helps attackers identify software versions	Minimize unnecessary version disclosure
Insecure HTTP methods	May allow unintended operations	Disable unnecessary HTTP methods

Note: These are potential findings, not confirmed scan results. Nikto output must be examined to determine which issues are present.

Security Risks

- Attackers may use exposed files to discover sensitive information.
- Outdated components may contain known vulnerabilities.
- Directory listing may reveal application files.
- Server banners may help attackers identify technologies and versions.
- Unnecessary HTTP methods may increase the attack surface.

Recommendations

1. Update the web server and application components.
2. Remove unnecessary files and directories.
3. Disable directory listing.
4. Configure suitable HTTP security headers.
5. Disable unnecessary HTTP methods.
6. Validate reported findings manually before classifying them as vulnerabilities.

7. Rescan after remediation to confirm that the issues have been addressed.

Result

Nikto helps identify common web server weaknesses and supports remediation and security verification.

---

3. DNS Enumeration Using Dig – zonetransfer.me

Aim

To enumerate DNS records, identify authoritative name servers, and determine whether an unauthorized DNS zone transfer is permitted.

Commands

1. Find the A record

dig zonetransfer.me A

2. Find the AAAA record

dig zonetransfer.me AAAA

3. Find mail servers

dig zonetransfer.me MX

4. Find authoritative name servers

dig zonetransfer.me NS

5. Find TXT records

dig zonetransfer.me TXT

6. Find the SOA record

dig zonetransfer.me SOA

7. Check a CNAME record

dig www.zonetransfer.me CNAME

8. Test DNS zone transfer

First, identify the authoritative name servers:

dig zonetransfer.me NS +short

Then, use an authoritative server returned by that command:

dig @<authoritative-server> zonetransfer.me AXFR

Replace <authoritative-server> with the actual name server hostname.

Analysis

DNS Record	Purpose	Security Importance
A	Maps a hostname to an IPv4 address	Identifies IPv4 hosts
AAAA	Maps a hostname to an IPv6 address	Identifies IPv6 hosts
MX	Identifies mail servers	Reveals email infrastructure
NS	Identifies authoritative name servers	Reveals DNS infrastructure
CNAME	Defines hostname aliases	Reveals relationships between hostnames
TXT	Stores text-based DNS information	May disclose domain policies or verification details
SOA	Provides DNS zone administration information	Reveals zone management details
AXFR	Requests a DNS zone transfer	May expose multiple DNS records if improperly authorized

Zone Transfer Analysis

A DNS zone transfer can expose a large collection of DNS records, including subdomains, hostnames, IP addresses, and server naming patterns.

If the transfer is refused, the server is not allowing that request from the testing source. If it succeeds, the response should be reviewed to determine which records were exposed and whether that access is authorized.

Security Risks

- Exposure of internal or overlooked hostnames.
- Disclosure of mail and server infrastructure.
- Discovery of additional systems for security testing.
- Increased reconnaissance opportunities if unrestricted zone transfers are permitted.

Recommendations

1. Restrict zone transfers to authorized secondary DNS servers.
2. Review public DNS records and remove obsolete entries.
3. Protect administrative DNS interfaces.

4. Use appropriate DNS access controls and monitoring.
5. Review TXT records for accidental disclosure.
6. Retest AXFR after applying restrictions.

Result

Dig helps identify DNS records, authoritative servers, and potential information disclosure through unrestricted zone transfers.

Important: zonetransfer.me is a deliberately configured DNS zone commonly used for testing zone-transfer behavior. Do not assume its results represent the security posture of a production organization.

---

4. SMB Enumeration Using Enum4linux – 192.168.1.100

Aim

To identify SMB shares, user accounts, groups, domain information, and security weaknesses on the authorized Windows target.

Commands

1. Basic enumeration

enum4linux 192.168.1.100

2. Enumerate users

enum4linux -U 192.168.1.100

3. Enumerate groups

enum4linux -G 192.168.1.100

4. Enumerate shared resources

enum4linux -S 192.168.1.100

5. Enumerate operating system and domain information

enum4linux -o 192.168.1.100

6. Perform broader enumeration

enum4linux -a 192.168.1.100

The exact options available may vary by Enum4linux version. Use enum4linux -h if a command is unsupported.

Analysis

Information	Purpose	Security Risk
User accounts	Identifies existing accounts	May support targeted credential attacks
Groups	Identifies group membership	May reveal privilege relationships
SMB shares	Identifies shared resources	Unauthorized access to files
Domain/workgroup	Identifies network organization	Helps map the environment
OS information	Identifies the operating system	Supports vulnerability research
Password policy	Reveals authentication requirements	May expose weak security policies
NetBIOS information	Provides system identification details	Helps network reconnaissance

Security Risks

1. Anonymous or null-session access may expose information without authentication.
2. Excessively permissive shares may expose sensitive files.
3. User and group information may help attackers plan targeted attacks.
4. Outdated SMB implementations may contain known vulnerabilities.
5. Unrestricted SMB access may facilitate unauthorized access or lateral movement.

Recommendations

- Disable unnecessary SMB services.
- Restrict SMB access to trusted systems and networks.
- Disable anonymous access where unnecessary.
- Apply least-privilege permissions to shared folders.
- Enforce strong passwords and appropriate account policies.
- Install operating system and SMB security updates.
- Monitor failed logins and unusual file-sharing activity.
- Use network segmentation to isolate sensitive systems.

Result

Enum4linux helps identify information exposed through SMB and supports improvements to Windows network security.

Note: The actual users, groups, shares, and domain details must be taken from the enumeration output. They cannot be determined from the IP address alone.

5. Service Banner Analysis Using Netcat – scanme.nmap.org

Aim

To connect to accessible TCP services and identify information disclosed through service banners and HTTP responses.

Commands

1. Check an SSH service

nc -nv scanme.nmap.org 22

2. Connect to an HTTP service

nc -nv scanme.nmap.org 80

After connecting to port 80, enter:

HEAD / HTTP/1.1

Host: scanme.nmap.org

Connection: close

Press **Enter twice** after the final header.

Analysis

Information	Description	Security Risk
Service name	Identifies the running service	Helps fingerprint the target
Software version	May identify a specific implementation	Supports vulnerability research
HTTP headers	Reveal web server response information	May disclose implementation details
Protocol information	Identifies supported communication protocols	Helps identify configuration weaknesses
OS clues	May be inferred from service responses	Helps narrow down the operating system
Error messages	May reveal technical details	May disclose unnecessary information

Security Risks

- Service banners may reveal software names and versions.
- Attackers can compare disclosed versions with public vulnerability information.

- HTTP headers may expose unnecessary implementation details.
- Accurate fingerprinting may help attackers choose more targeted attack techniques.

Important: Banner disclosure alone does not prove that a service is vulnerable. The reported software version must be verified, and any suspected vulnerability requires additional testing.

Recommendations

1. Update exposed services regularly.
2. Disable unnecessary services and ports.
3. Minimize unnecessary version information in banners and HTTP headers.
4. Use firewalls to restrict access to services that do not need to be public.
5. Monitor externally exposed services and connection attempts.
6. Periodically reassess the external attack surface.
7. Validate suspected vulnerabilities before assigning a final severity rating.

Result

Netcat helps collect service responses and banner information, supporting service identification and external security assessment.